

ASTRA · 星辰 —— AI 攻防全链路 Agent 技术方案

一、项目概述

ASTRA 是一套面向 AI 攻防全链路的状态空间搜索与决策引擎。它不预设角色与 workflow，只维护一张「星图」：给定起点（Origin）与目标（Goal），引擎在未知状态空间中持续搜索可行路径——漏洞挖掘、渗透测试、靶场闯关只是它已证明的第一片星域。

与「把提示词写得更小心」的常规方案不同，ASTRA 把可靠性建立在运行时机制上：上下文有治理、决策有对抗、失败有学习、结论有证据。模型负责理解、推理与生成，引擎负责把模型接入真实目标、真实工具与真实验证。

二、总体架构

ASTRA 由三层构成：

1. 星图核心 (Star Chart): 状态空间的事实-航向图，三个原语:

- 星记 (Stellar): 一条已确认的客观发现 (漏洞、端口、凭据、flag)，携带置信度、证据链与挑战状态;
- 航向 (Bearing): 一个声明但未执行的探索方向;
- 指引 (Guidance): 任意时刻注入的判断 (人类或系统)，作为风险提示进入后续推理。

2. 领航调度 (Navigator): 以 OODA 循环驱动四种任务——首探 (Probe, 直接尝试解题)、定航 (Navigate, 判断目标是否达成并规划方向)、巡猎 (Patrol, 认领航向并执行探索)、整理 (Consolidate, 记忆压缩)。

3. 星探执行 (Scout): 接入国内大模型 CLI (DeepSeek / Qwen / GLM 的 Anthropic 或 OpenAI 兼容端点)，支持 Docker 与 local 双执行模式; local 模式以宿主进程运行，适配托管平台与离线环境。

全流程自动化由 `astra-runner` 编排器完成: 它连接评测平台 (TSecBench)，完成题目容器的启动/关闭、为每题创建 ASTRA 项目、从星图收集 flag 统一提交 (幂等)、输出每题得分与耗时报告——从题目下发到成绩回收全程无人值守。

三、核心机制

3.1 星尘记忆：上下文三层治理

传统 Agent 把整张图的历史无差别塞进每次推理，token 随图线性膨胀。ASTRA 做三层治理：

- **焦点子图 (Focus)**：每次推理只内联与当前航向/目标最相关的星记与航向（相关度 × 时间近度打分），受 `context_budget` 硬上限约束；完整星图仅以文件引用保留，按需读取；
- **摘要记忆 (Epitome)**：星记数超过预算阈值时自动触发整理任务，由轻量模型把最老的一批星记压缩为摘要星记，prompt 只呈现摘要；
- **零膨胀保证**：内联量恒有硬上限，不随星图规模增长（端到端测试断言）。

效果：长任务上下文稳定，单题推理成本可控，模型注意力集中在当前决策链。

3.2 双星决策：对抗式关键决策

单一智能体的自问自答容易方向漂移，尤其「宣布完成」这类高风险结论。ASTRA 对关键决策引入对抗式双星机制：

- **机器预审**：提案先过本地契约校验（引用星记必须存在、结构与语义合法、声明与星图证据匹配）；
- **质询（Challenge）**：独立批判视角审查提案——输出反驳意见与置信度评估（low/medium/high），拒绝橡皮图章；
- **裁决（Verdict）**：综合提案与质询做最终裁定，内置目标对齐评估，通过才写入星图；否决后把否决原因写回为指引，防止同一方向原地打转。

审查链路有预算与退出条件：超时、解析失败即保守不写回，绝不让未经审查的完成声明进入星图。质询与裁决使用轻量模型，只对关键节点触发，成本可控。

3.3 证据链与失败学习

- **证据标注**：巡猎产出必须自评置信度并附证据摘要（执行过的命令、工具输出、文件摘录）；无证据的推断不允许

写为星记；flag 类星记要求完整精确的 `flag{...}` 字符串；

- **失败学习**：命令失败、审查否决等真实失败被脱敏后沉淀为指引（风险提示），注入后续推理轮次——教训只作风险提示，绝不充当完成证据，防止「记住失败」被误当「验证成功」；
- **验证边界**：flag 正确性以平台提交返回为准（`correct/awarded`），星图推断与平台验证严格分离。

3.4 无效尝试抑制与进展评估

行业基准（Cybench：GPT-4 agent 仅完成 3/15 且时间大量耗在侦察与无效尝试；AutoPenBench：202+ 挑战平均完成约 27%，最弱环节是“判断何时停止”）表明：自主 agent 的瓶颈不在能力而在**路线纪律**。ASTRA 的应对：

- 定航规则显式化：已被 `[失败学习]` / `[审查否决]` 指引标记的方向不得重复提案；
- 进展评估：优先收敛已有航向，连续无产出的航向被替换而非追加同类；
- 每条 objection 必须引用星图证据或指出证据缺口，禁止无依据质疑（对齐 CRITIC 的工具交互批判思想）。

3.5 混合模型舰队与托管适配

- **DS+GLM 混合舰队**：探索位（首探/巡猎）由 DeepSeek v4 Flash 承担——吞吐高、工具调用稳定、缓存命中率高（实测单轮 4.2 亿 token 中 91% 为缓存命中）；决策位（定航/裁决/整理）由 GLM-5.3 最高推理档承担——低频高价值场景吃深度推理红利。双 key 双通道注入即自动渲染 4 worker 舰队（DS 探索×3 + GLM 探索×2 + GLM 决策×2 + DS 兜底×2），同一道题的多个航向由不同模型并行探索（快攻 + 深挖多路并进），单通道故障按优先级自动回退；
- **Docker 模式**：星探 CLI 在每项目容器中执行，隔离环境、工具完备（Kali 工具链 + nuclei/impacket/cloudfox 等）；
- **local 模式**：宿主进程直接执行，无需 Docker；托管平台受限环境下以该模式运行，镜像内置完整引擎，`astra-runner` 作为默认入口自启动，大模型 API 经平台网关访问。

3.6 稳定性工程（6 小时无人值守的工程保障）

- **开题策略**：easy→medium→hard 排序开题，杜绝低分题

被排队饿死（实测教训：一轮因平台原始顺序 16 道题未进队列）；

- **分级 hint**：卡题 15/30 分钟自动取平台提示、45 分钟保留进度放回队尾（每题最多 defer 2 次），避免死磕单题拖垮吞吐；
- **断点续跑**：每题 start/关题落盘进度文件，崩溃重启自动跳过已完成题；
- **模型 watchdog**：双端点探活 + 会话 403 扫描，配额耗尽秒级告警（实测教训：一轮因 key 配额静默空转 1 小时）；
- **全程可审计**：每题输出星记数/指引数/耗时/得分/token 消耗（分模型统计 input/output/cache_read/reasoning）与首 flag 时长。

四、六大评测维度覆盖

维度	权重	ASTRA 的应对
WEB 漏洞挖掘	20%	自动化探索（nuclei/ffuf/katana/dalfox）+ 源码审计（gitleaks/危险函数检索）；多航向并行，逐层收敛

维度	权重	ASTRA 的应对
EXPLOIT 漏洞利用	20%	PoC 模板库 (/home/kali/pocs) + 工具链 (ysoserial/jwt_tool)； 利用成果以证据链写回
KILLCHAIN 多阶段渗透	20%	多步攻击链编排 (impacket/chisel/proxychains/kerbrute)， tmux 维持持续会话， 横向移动与权限维持
BINARY 二进制挖掘	15%	pwntools/gdb 逆向分析， 源码优先审计危险函数与长度校验
CLOUD 云攻击	15%	元数据服务、存储桶枚举 (cloudfox/awscli/tccli)、 IAM 提权、容器逃逸 (capsh/cgroup/docker.sock)

维度	权重	ASTRA 的应对
EVASION 对抗规避	10%	WAF 绕过（编码混淆/分块传输/参数污染）、免杀思路、流量隐匿

引擎以航向（Bearing）驱动并行探索，按证据收敛度动态分配算力；星图保证各维度的发现不丢失、不重复、可追溯。

五、实验结果与量化对比

5.1 真实靶场实测（TSecBench v1 旗舰集，63 题 / 74 flag / 满分 23000）

轮次	底层配置	得分	答对 flag	完成率	综合得分
1	单模型（旧栈）	8740	—	—	—
2	DS v4 Flash 单模型	11720	38/74	51.4%	50.26
3	GLM（端点工具调用缺陷废 2h）→ DS 接管	8350	26/74	—	—
4	DS（回退旧栈 + 原始开题顺序）	10490	35/74	47.3%	42.49

六维明细（最佳轮）：对抗规避 13/14、漏洞利用 7/9、Web 12-14/18、云攻击 5/6；

逐轮复盘驱动的机制迭代（开题排序、混合舰队、hint 分级、watchdog）均有测试回归保障。

5.2 机制量化对比

量化指标	ASTRA	传统人工/脚本模式
单题发现→提交全流程	全自动（astra-runner 无人值守，人机验证时间比例趋近于零）	人工盯守
上下文 token 消耗	内联量硬上限，随图不增长；单轮 4.2 亿 token 中 91% 缓存命中	线性增长，长任务易爆
关键决策审查	每提案质询+裁决（机器+LLM 双层），首轮通过率约 70%，修正后显著提升	无对抗审查

量化指标	ASTRA	传统人工/脚本模式
大模型运行成本	混合舰队（探索用 Flash 控成本 + 决策用 GLM 吃深度） + 焦点子图裁剪	单一模型全量投喂
误报抑制	置信度+证据链+质询三重过滤	依赖个人经验
无效尝试抑制	失败 / 否决指引标记，定航禁止重复方向	无（行业基准显示无效尝试是最大耗时长源）
每题统计口径	星记数/指引数/驳回数/耗时/得分/分模型 token 全记录	人工整理

评估口径：漏洞发现率以平台 flag 提交正确数计；误报率以被质询否决的提案占比计；代码审计量级以巡猎产出星记数计；单高危漏洞发现时长以项目完成到提交的耗时计（报告含 first_flag_seconds）。

六、创新点总结

- 1. 星尘记忆：焦点子图 + 摘要压缩 + 硬预算，解决长任务上下文膨胀这一 Agent 通病；
- 2. 双星决策：对抗式质询-裁决机制，把「模型自信」与

「工程结论」分离，方向正确性有机制保障而非提示词保障；

3. **证据与验证分离**：星图证据链与平台真实验证严格分层，教训只进风险提示、不进完成证据；
4. **混合模型舰队**：探索与决策分治——吞吐型模型铺量、深度推理模型攻坚，同题多航向跨模型并行，故障自动回退；
5. **全链路自动化**：从题目下发、探索、flag 收集提交到成绩报告，全程无人值守，人机验证时间比例趋近于零；开题排序/分级 hint/断点续跑/watchdog 让 6 小时以上长窗口稳定满载（实测四轮逐轮复盘迭代）；
6. **双模式弹性**：一套引擎同时适配容器隔离与受限托管环境（平台网关/环境变量注入/镜像自启动）。

七、安全声明

本系统仅用于获得明确授权的安全测试与竞赛环境，使用者须自行承担合规责任。